

Лекция 2: Методы обнаружения вторжений

1. Сигнатурный подход :

I. Как работает сигнатурный анализ.

Сигнатурный анализ — это метод обнаружения угроз в информационной безопасности, основанный на сравнении данных (например, файлов, сетевых пакетов или поведения программ) с заранее известными "подписями" (сигнатурами), которые характеризуют конкретные угрозы, такие как вредоносное ПО (malware), вирусы, черви, трояны и другие виды атак. Этот метод является одним из самых распространённых и традиционных подходов к защите систем от киберугроз.

Принцип работы сигнатурного анализа:

1. Создание базы сигнатур :

- Специалисты по информационной безопасности анализируют известные угрозы и выделяют уникальные характеристики (сигнатуры), которые позволяют однозначно идентифицировать конкретное вредоносное ПО или атаку. Эти характеристики могут включать:
 - Фрагменты кода.
 - Хэши файлов (например, MD5, SHA-256).
 - Определённые последовательности байтов.
 - Шаблоны сетевой активности.
 - Структуру файлов или их заголовки.
- Полученные сигнатуры заносятся в базу данных (базу сигнатур), которая регулярно обновляется.

2. Сканирование данных :

- Антивирусные программы или системы защиты анализируют файлы, сетевые пакеты или другие данные на наличие совпадений с сигнатурами из базы.
- Для этого используется алгоритм сравнения: проверяемый объект (например, файл или поток данных) сравнивается с каждой сигнатурой из базы.

3. Обнаружение угрозы :

- Если найдено совпадение между проверяемым объектом и одной из сигнатур, система определяет объект как угрозу.
- После обнаружения угрозы выполняются предопределённые действия, такие как:
 - Удаление файла.
 - Карантин подозрительного объекта.
 - Блокировка сетевого соединения.
 - Уведомление пользователя или администратора.

4. Обновление базы сигнатур :

- Поскольку новые угрозы постоянно появляются, важно регулярно обновлять базу сигнатур. Это делается через облачные сервисы или локальные обновления.
- Обновления могут содержать новые сигнатуры для недавно обнаруженных угроз, а также улучшения алгоритмов обнаружения.

Преимущества сигнатурного анализа:

1. Высокая точность :

- Сигнатурный анализ эффективен для обнаружения известных угроз, так как он основан на точном совпадении с заранее определёнными шаблонами.

2. **Простота реализации :**

- Метод относительно прост в реализации и требует минимальных ресурсов для сравнения данных с базой сигнатур.

3. **Быстрота обнаружения :**

- При наличии актуальной базы сигнатур, угрозы можно обнаружить практически мгновенно.

Недостатки сигнатурного анализа:

1. **Неэффективность против новых угроз :**

- Сигнатурный анализ не способен обнаруживать ранее неизвестные угрозы (zero-day атаки), так как для них ещё нет сигнатур.

2. **Зависимость от обновлений :**

- Эффективность метода напрямую зависит от регулярности обновления базы сигнатур. Если база устарела, система становится уязвимой.

3. **Ложные срабатывания :**

- В некоторых случаях невредоносные файлы или процессы могут быть ошибочно идентифицированы как угрозы, если они случайно соответствуют сигнатуре.

4. **Ресурсоёмкость при большом объёме данных :**

- При работе с большими объёмами данных (например, в корпоративных сетях) процесс сканирования может потребовать значительных вычислительных ресурсов.

Пример использования:

Предположим, что антивирусная программа получила файл для проверки. Она выполняет следующие шаги:

1. Вычисляет хэш-сумму файла (например, SHA-256).
2. Сравнивает её с хэш-суммами из базы сигнатур.
3. Если хэш совпадает с сигнатурой известного вредоносного файла, программа помечает файл как угрозу и принимает меры (например, удаляет его).

Альтернативные подходы:

Для компенсации недостатков сигнатурного анализа часто используются дополнительные методы:

- **Эвристический анализ :** Оценивает поведение файла или программы, чтобы обнаружить потенциально вредоносные действия, даже если сигнатура отсутствует.
- **Анализ поведения :** Отслеживает действия программы в реальном времени и блокирует подозрительное поведение.
- **Машинное обучение :** Использует алгоритмы для выявления аномалий и классификации угроз на основе исторических данных.

Заключение:

Сигнатурный анализ остаётся важным инструментом в арсенале средств защиты информации. Однако его эффективность максимальна только в сочетании с другими методами, такими как эвристика и машинное обучение. Современные системы защиты

обычно комбинируют несколько подходов для обеспечения надёжной защиты от широкого спектра угроз.

II. Преимущества и недостатки.

Сигнатурный подход — это один из методов обнаружения угроз в системах информационной безопасности, основанный на сравнении фрагментов данных (например, файлов, сетевых пакетов или поведения программ) с базой известных сигнатур (уникальных характеристик) вредоносного ПО. Этот подход широко используется в антивирусных программах, системах предотвращения вторжений (IDS/IPS) и других инструментах защиты.

Преимущества сигнатурного подхода:

1. *Высокая точность обнаружения известных угроз :*

- Сигнатурный подход эффективен для обнаружения уже известных вредоносных программ, так как сигнатуры создаются на основе анализа конкретных образцов вредоносного ПО.
- Если сигнатура совпадает, можно быть уверенным, что обнаруженная активность действительно представляет собой угрозу.

2. *Простота реализации :*

- Алгоритмы сравнения сигнатур относительно просты и не требуют сложных вычислений. Это делает сигнатурный подход быстрым и эффективным для обработки больших объемов данных.

3. *Низкий уровень ложноположительных срабатываний :*

- Поскольку сигнатуры создаются на основе уникальных характеристик конкретных угроз, вероятность ошибочного срабатывания (ложноположительных результатов) минимальна.

4. *Широкое распространение :*

- Сигнатурный подход является стандартом в антивирусных решениях и поддерживается большинством производителей ПО для защиты от вредоносных программ.

5. *Быстрое обновление баз данных :*

- Производители антивирусов могут быстро добавлять новые сигнатуры в базы данных по мере появления новых угроз, что позволяет оперативно реагировать на эволюцию вредоносного ПО.

Недостатки сигнатурного подхода:

1. *Неэффективность против новых (неизвестных) угроз :*

- Сигнатурный подход не способен обнаруживать новые виды вредоносного ПО, для которых еще нет сигнатуры. Это создает "окно уязвимости" между появлением новой угрозы и выпуском соответствующей сигнатуры.

2. *Зависимость от регулярных обновлений :*

- Для обеспечения эффективности сигнатурный подход требует постоянного обновления баз данных сигнатур. Без своевременных обновлений система становится уязвимой к новым атакам.

3. *Уязвимость к полиморфизму и обфускации :*

- Современные вредоносные программы часто используют техники изменения своего кода (полиморфизм, метаморфизм, шифрование), чтобы избежать обнаружения по сигнатуре. Это значительно снижает эффективность сигнатурного подхода.

4.	Ограниченная защита от целевых атак :
	Целевые атаки (APT — Advanced Persistent Threats) часто используют уникальные, специально созданные для конкретной цели вредоносные программы, которые не имеют известных сигнатур. В таких случаях сигнатурный подход бесполезен.
5.	Ресурсоемкость при работе с большими базами данных :
	По мере роста числа известных угроз базы данных сигнатур становятся все больше, что увеличивает время на поиск совпадений и требует больше вычислительных ресурсов.
6.	Неэффективность против сложных поведенческих атак :
	Сигнатурный подход ориентирован на статический анализ (поиск известных фрагментов кода), но не может эффективно обнаруживать сложные поведенческие атаки, такие как эксплуатация уязвимостей нулевого дня или использование легитимных инструментов для злонамеренных целей.
7.	Отсутствие адаптивности :
	Сигнатурный подход не обладает механизмами самообучения или адаптации к новым типам угроз. Он полностью зависит от внешних обновлений сигнатур.

Заключение:

Сигнатурный подход остается важным элементом современных систем защиты, особенно для борьбы с массовыми и хорошо известными угрозами. Однако его недостатки делают его недостаточным в качестве единственного механизма защиты. Поэтому на практике сигнатурный подход часто комбинируют с другими методами, такими как поведенческий анализ, эвристический анализ и машинное обучение, чтобы обеспечить более комплексную защиту от широкого спектра угроз.

Итоговый вывод:

Сигнатурный подход эффективен для обнаружения известных угроз, но имеет ограничения в борьбе с новыми, сложными и целевыми атаками. Его использование должно дополняться другими технологиями для повышения общей безопасности системы.

III. Примеры сигнатур для известных атак.

Сигнатуры атак — это уникальные паттерны или последовательности данных, которые могут быть использованы для идентификации известных угроз в сетевом трафике, файлах или системных действиях. Эти сигнатуры используются антивирусными программами, IDS/IPS (системы обнаружения и предотвращения вторжений) и другими инструментами безопасности для выявления и блокировки атак. Ниже приведены примеры сигнатур для некоторых известных типов атак.

1. SQL-инъекция

SQL-инъекция — это атака, при которой злоумышленник внедряет вредоносный SQL-код в запросы к базе данных через пользовательский ввод.

Пример сигнатуры:

"UNION SELECT", "DROP TABLE", "OR 1=1", ";--"

Описание:

- UNION SELECT** — используется для объединения результатов запросов.
- DROP TABLE** — команда для удаления таблицы.
- OR 1=1** — логическое выражение, которое всегда истинно, часто используется для обхода проверок авторизации.
- ;** **--** — символы для завершения текущего запроса и добавления комментария.

2. Межсайтовый скриптинг (XSS)

XSS-атаки происходят, когда злоумышленник внедряет вредоносный JavaScript-код на страницу, который затем выполняется в браузере жертвы.

Пример сигнатуры:

```
"<script>", "javascript:", "onerror=", "alert("
```

Описание:

- **<script>** — HTML-тег, используемый для внедрения JavaScript.
- **javascript:** — протокол, используемый для выполнения JavaScript в URL.
- **onerror=** — атрибут HTML, который может быть использован для выполнения кода при ошибке.
- **alert(** — часто используется в тестовых XSS-атаках для проверки уязвимости.

3. Атака "Переполнение буфера"

Эта атака эксплуатирует уязвимость в программном обеспечении, связанную с некорректной обработкой входных данных, что приводит к перезаписи памяти.

Пример сигнатуры:

```
"\x90\x90\x90\x90", "\xEB\xFE", "AAAAAAAAAAAAAAAAAAAAAAAAAAAA"
```

Описание:

- **\x90** — NOP-слайд (No Operation), часто используется для заполнения буфера перед выполнением вредоносного кода.
- **\xEB\xFE** — машинный код для бесконечного цикла, который может указывать на попытку эксплуатации.
- Длинная последовательность символов **A** (или других повторяющихся символов) может указывать на попытку переполнения буфера.

4. DDoS-атака (Distributed Denial of Service)

DDoS-атаки направлены на перегрузку сервера или сети большим количеством запросов.

Пример сигнатуры:1

```
"GET / HTTP/1.1\r\nHost: target.com\r\nUser-Agent: Mozilla/5.0\r\n\r\n"
```

Описание:

- Повторяющиеся HTTP-запросы (например, **GET**) с одинаковым User-Agent или IP-адресом могут указывать на DDoS-атаку.
- Большое количество одновременных подключений к одному ресурсу.

5. Атака "Man-in-the-Middle" (MITM)

Эта атака происходит, когда злоумышленник перехватывает или модифицирует трафик между двумя сторонами.

Пример сигнатуры

```
"Certificate not trusted", "Self-signed certificate", "Mismatched domain name"
```

Описание:

- Сообщения о недоверенных сертификатах SSL/TLS могут указывать на попытку MITM-атаки.
- Самоподписанные сертификаты или несоответствие имени домена в сертификате и URL-адресе также являются красными флажками.

6. Атака "Brute Force"

Brute Force — это метод подбора паролей путем перебора всех возможных комбинаций.

Пример сигнатуры:

```
"Failed login attempts: 10", "POST /login.php",  
"username=admin&password="
```

Описание:

- Множественные неудачные попытки входа с одного IP-адреса.
- Повторяющиеся POST-запросы к странице входа с разными значениями логина и пароля.

7. Атака "Ransomware"

Ransomware шифрует файлы жертвы и требует выкуп за их восстановление.

Пример сигнатуры:

```
".encrypt", ".locked", "Your files are encrypted", "Pay Bitcoin"
```

Описание:

- Изменение расширений файлов на `.encrypt`, `.locked` и т. д.
- Сообщения о шифровании файлов и требования выкупа.
- Использование криптовалюты (например, Bitcoin) для оплаты выкупа.

8. Атака "Phishing"

Phishing-атаки направлены на получение конфиденциальной информации (например, логинов и паролей) через поддельные сайты или электронные письма.

Пример сигнатуры:

```
"Dear customer", "Please verify your account", "Click here to reset  
password"
```

Описание:

- Стандартные фразы, используемые в phishing-письмах.
- Подозрительные ссылки или домены, похожие на легальные.

Заключение

Сигнатуры атак постоянно обновляются, так как злоумышленники находят новые способы обхода защитных механизмов. Современные системы безопасности используют не только статические сигнатуры, но и поведенческий анализ, машинное обучение и другие методы для выявления новых угроз. Если вас интересуют более конкретные примеры или детали реализации сигнатур для определенного типа атак, уточните вопрос, и я предоставлю дополнительную информацию.

IV. Аномальный подход :

Определение нормального поведения системы

Нормальное поведение системы — это совокупность характеристик, параметров и действий системы, которые соответствуют её ожидаемым, предсказуемым и заранее определённым функциям в рамках заданных условий эксплуатации. Это понятие широко используется в различных областях, таких как информационные технологии, инженерия, кибербезопасность, медицина и другие.

Ключевые аспекты нормального поведения системы:

1. Соответствие спецификациям:

- - Система работает в соответствии с её техническими требованиями, функциональными спецификациями и проектной документацией.
- Например, если система должна обрабатывать 100 запросов в секунду, то её способность делать это без ошибок является признаком нормального поведения.

2. Стабильность и надёжность:

- Система демонстрирует стабильную работу без внезапных сбоев, перебоев или отказов.
- Показатели производительности остаются в допустимых пределах (например, время отклика не превышает установленный порог).

3. Предсказуемость:

- Поведение системы можно прогнозировать на основе её прошлого поведения и текущих входных данных.
- Например, если система реагирует на определённые события всегда одинаково, это указывает на её нормальное функционирование.

4. Отсутствие аномалий:

- В системе отсутствуют необычные или непредвиденные паттерны поведения, такие как резкие скачки нагрузки, необъяснимые ошибки или несанкционированные действия.

5. Корректность выходных данных:

- Результаты работы системы соответствуют ожидаемым значениям и логике её функционирования.
- Например, корректность расчётов, отсутствие искажений данных или ошибок в выводе информации.

6. Соответствие внешним условиям:

- Система адаптируется к изменениям окружающей среды, но при этом сохраняет свою работоспособность.
- Например, серверная система может корректно обрабатывать увеличение трафика в часы пик.

7. Безопасность:

- Система защищена от угроз, и её работа не нарушается из-за внешних атак или внутренних ошибок безопасности.
- Например, отсутствие подозрительных входящих соединений или несанкционированного доступа

Методы определения нормального поведения системы:

1. Мониторинг и анализ данных:

- Использование инструментов мониторинга для сбора метрик (например, загрузка процессора, использование памяти, сетевой трафик).
- Пример: системы APM (Application Performance Management) для анализа производительности приложений.

2. Моделирование и машинное обучение:

- Создание моделей нормального поведения на основе исторических данных.
- Пример: использование алгоритмов машинного обучения для выявления аномалий в поведении системы.

3. Тестирование:

- Проведение нагрузочного, стрессового и функционального тестирования для проверки поведения системы в различных условиях.
- Пример: тестирование на отказоустойчивость (failover testing).

4. Логирование и аудит:

- Анализ журналов событий для выявления отклонений от нормы.
- Пример: использование SIEM-систем (Security Information and Event Management) для анализа логов.

5. Определение базовых показателей (бенчмаркинг):

- Установление эталонных значений для ключевых метрик системы, которые служат отправной точкой для сравнения.

- Пример: определение среднего времени отклика системы в нормальных условиях.

Примеры нормального и аномального поведения систем

ХАРАКТЕРИСТИКА	НОРМАЛЬНОЕ ПОВЕДЕНИЕ	АНОМАЛЬНОЕ ПОВЕДЕНИЕ
Загрузка процессора	Стабильная загрузка в пределах 30-70%.	Внезапный рост до 100% без видимых причин.
Сетевой трафик	Равномерное распределение трафика в течение дня.	Резкий всплеск исходящего трафика ночью.
Логи системы	Отсутствие ошибок или предупреждений.	Появление множества ошибок "Access Denied".
Время отклика	Время отклика < 200 мс.	Время отклика > 1000 мс без объяснения причин.

Заключение

Определение нормального поведения системы является важным шагом для обеспечения её эффективности, безопасности и надёжности. Это позволяет своевременно выявлять отклонения, предотвращать сбои и минимизировать риски. Для достижения этого используются различные методы анализа, мониторинга и моделирования, которые помогают создать чёткое представление о том, как система должна функционировать в нормальных условиях.

V. Выявление отклонений системы от нормы

Выявление отклонений от нормы системы — это процесс мониторинга, анализа и обнаружения аномалий или нештатных ситуаций в работе информационных систем, оборудования или процессов. Этот процесс играет ключевую роль в обеспечении надёжности, безопасности и эффективности работы любой системы. Рассмотрим основные подходы, методы и инструменты для выявления отклонений.

1. Основные этапы выявления отклонений

1.1. Определение нормального поведения системы

Для обнаружения отклонений необходимо четко понимать, как система должна работать в нормальных условиях. Это включает:

- Сбор исторических данных о работе системы.
- Анализ метрик (например, загрузка процессора, использование памяти, сетевой трафик).
- Установление пороговых значений для ключевых параметров.

1.2. Мониторинг текущего состояния

Система должна постоянно отслеживать свои параметры в реальном времени. Для этого используются:

- Средства мониторинга (например, Zabbix, Prometheus, Grafana).
- Логирование событий (ELK Stack: Elasticsearch, Logstash, Kibana).
- Сбор данных с датчиков или IoT-устройств.

1.3. Обнаружение аномалий

На этом этапе происходит сравнение текущих данных с эталонными значениями. Аномалии могут быть:

- **Статистические** : выход за пределы допустимого диапазона.

- **Контекстные** : отклонения, зависящие от времени, нагрузки или других факторов.
- **Поведенческие** : изменения в шаблонах поведения пользователей или системы.

1.4. Реакция на отклонения

После обнаружения аномалии система должна:

- Уведомить администратора или ответственных лиц.
- Автоматически принять меры (например, перезапустить сервис, заблокировать подозрительный IP).
- Записать данные для дальнейшего анализа.

2. Методы выявления отклонений

2.1. Статистические методы

- **Z-оценка** : Оценка того, насколько значение отклоняется от среднего.
- **Метод скользящего среднего** : Выявление трендов и аномалий на основе средних значений за определенный период.
- **Квантильные методы** : Использование процентилей для определения границ нормального поведения.

2.2. Машинное обучение

- **Надзорные методы** : Классификация данных на "нормальные" и "аномальные" на основе размеченных данных.
- **Безнадзорные методы** :
 - **Кластеризация** (например, k-means): Группировка данных и выделение выбросов.
 - **Изоляционный лес (Isolation Forest)**: Эффективный метод для обнаружения редких событий.
 - **Автокодировщики**: Обучение модели восстанавливать нормальные данные и выявлять отклонения.
- **Глубокое обучение** :
 - **Нейронные сети LSTM (Long Short-Term Memory)** для анализа временных рядов.
 - **Autoencoders** для обнаружения аномалий в сложных данных.

2.3. Правила и эвристики

- **Создание правил на основе экспертных знаний** (например, "если загрузка CPU > 90% более 5 минут, отправить уведомление").
- **Использование сигнатур известных аномалий или атак.**

2.4. Комбинированные методы

Часто используется комбинация статистических методов, машинного обучения и эвристик для повышения точности обнаружения аномалий.

3. Инструменты для выявления отклонений

3.1. Open-source решения

- **Prometheus + Alertmanager** : Мониторинг метрик и настройка оповещений.
- **Grafana** : Визуализация данных и создание дашбордов.
- **Elasticsearch + Kibana** : Анализ логов и обнаружение аномалий.
- **Scikit-learn** : Библиотека для реализации алгоритмов машинного обучения.

3.2. Коммерческие решения

- **Splunk** : Поиск и анализ больших объемов данных.
- **Datadog** : Мониторинг инфраструктуры и приложений.
- **IBM Watson AIOps** : Использование ИИ для обнаружения аномалий.

3.3. Специализированные инструменты

- Anodot : Автоматическое обнаружение аномалий в бизнес-метриках.
- Microsoft Azure Monitor : Мониторинг облачной инфраструктуры.
- AWS CloudWatch : Мониторинг и оповещения для AWS.

4. Примеры использования

4.1. IT-инфраструктура

- Мониторинг серверов: выявление высокой загрузки CPU, памяти или дисков.
- Обнаружение сетевых атак (DDoS, brute force).

4.2. Промышленность

- Контроль состояния оборудования: выявление отклонений в температуре, давлении или вибрации.
- Предсказание поломок с помощью анализа данных с датчиков.

4.3. Финансовые системы

- Обнаружение мошеннических транзакций.
- Мониторинг рыночных аномалий (например, внезапные скачки цен).

4.4. Медицина

- Анализ показателей пациента (пульс, давление, уровень сахара).
- Выявление отклонений в диагностических данных (например, на МРТ).

5. Рекомендации по внедрению

1. Определите цели мониторинга : Что именно нужно контролировать? Какие отклонения критичны?
2. Выберите подходящие инструменты : Учитывайте масштаб системы, бюджет и требования к точности.
3. Настройте пороги и правила : Убедитесь, что они соответствуют реальным условиям работы системы.
4. Обучите команду : Персонал должен понимать, как реагировать на уведомления.
5. Регулярно обновляйте модели : Системы меняются, поэтому важно поддерживать актуальность моделей и правил.

Заключение

Выявление отклонений от нормы системы — это комплексный процесс, требующий сочетания технологий, методов и экспертизы. Использование современных инструментов и подходов позволяет своевременно обнаруживать проблемы, минимизировать риски и повышать надежность системы.

VI. Примеры аномалий: необычные паттерны трафика, подозрительные действия пользователей.

Аномалии в трафике или действиях пользователей могут быть признаками потенциальных угроз, таких как кибератаки, мошенничество или сбои в работе систем. Рассмотрим несколько примеров необычных паттернов трафика и подозрительных действий пользователей:

Необычные паттерны трафика

1. Внезапный всплеск входящего или исходящего трафика

- Пример: Сервер компании обычно обрабатывает 100 МБ данных в час, но внезапно начинает получать или отправлять 10 ГБ данных за то же время.
- Возможные причины:
 - DDoS-атака (распределенная атака типа "отказ в обслуживании").

	• Утечка данных через несанкционированный канал. • Неправильная настройка системы.
2.	Ночное увеличение активности
	• Пример: Трафик значительно возрастает в нерабочее время, например, в 3 часа ночи, когда сотрудники компании неактивны. • Возможные причины: ✓ Атака злоумышленников из другого часового пояса. ✓ Автоматизированные скрипты или боты, работающие без разрешения.
3.	Подключение с необычных IP-адресов или географических локаций
	• Пример: Пользователь, проживающий в России, внезапно подключается к корпоративной сети с IP-адреса, зарегистрированного в Бразилии. • Возможные причины: ✓ Компрометация учетной записи. ✓ Использование прокси-серверов или VPN для сокрытия истинного местоположения.
4.	Повторяющиеся запросы к одному и тому же ресурсу
	• Пример: Одна и та же система отправляет сотни запросов к определенному API или файлу в течение нескольких минут. • Возможные причины: ✓ Попытка эксплуатации уязвимости (например, SQL-инъекция). ✓ Ошибка в конфигурации клиента.
5.	Нестандартные порты или протоколы
	• Пример: Обычно используется HTTPS (порт 443), но внезапно начинается активность на порту 6667 (обычно используется для IRC). • Возможные причины: ✓ Злоумышленник использует нестандартные порты для передачи данных. ✓ Вредоносное ПО создает скрытые каналы связи.

Подозрительные действия пользователей

1.	Множественные попытки входа в систему
	• Пример: Пользователь делает 50 попыток войти в систему за 10 минут, используя разные пароли. • Возможные причины: ✓ Подбор пароля (brute-force атака). ✓ Утерянный пароль или компрометация учетной записи.
2.	Доступ к нехарактерным ресурсам
	• Пример: Сотрудник отдела продаж внезапно запрашивает доступ к файлам финансового отдела или серверу базы данных. • Возможные причины: ✓ Учетная запись скомпрометирована. ✓ Сотрудник пытается получить доступ к информации, не связанной с его обязанностями.
3.	Изменение важных настроек системы без уведомления
	• Пример: Администратор изменяет правила фаервола или добавляет новых пользователей в систему, хотя это не было запланировано. • Возможные причины: ✓ Инсайдерская угроза (недобросовестный сотрудник). ✓ Компрометация учетной записи администратора.
4.	Скачивание больших объемов данных

	• Пример: Пользователь скачивает 10 ГБ файлов за один день, хотя обычно работает только с документами размером до 100 МБ. • Возможные причины: ✓ Подготовка к утечке данных. ✓ Кража интеллектуальной собственности.
5.	Использование общих учетных записей или обход аутентификации • Пример: Несколько человек используют одну общую учетную запись для входа в систему, хотя политика безопасности требует индивидуальных учетных записей. • Возможные причины: ✓ Нарушение политик безопасности. ✓ Скрытие действий конкретного пользователя.
6.	Частая смена устройств или браузеров • Пример: Пользователь обычно авторизуется с одного устройства и браузера, но внезапно начинает использовать разные устройства и браузеры. • Возможные причины: ✓ Компрометация учетной записи. ✓ Использование сторонних инструментов для автоматизации действий.
7.	Удаление или изменение журналов аудита • Пример: Пользователь удаляет или очищает лог-файлы, связанные с его действиями. • Возможные причины: ✓ Попытка скрыть следы недобросовестных действий. ✓ Инсайдерская угроза.

Как выявить аномалии?

Для обнаружения аномалий можно использовать следующие методы:

1.	Мониторинг трафика в реальном времени : • Анализ сетевых пакетов с помощью инструментов, таких как Wireshark или Zeek. • Использование SIEM-систем (например, Splunk, ELK Stack) для сбора и анализа логов.
2.	Машинное обучение и анализ поведения : • Создание профилей пользователей и систем на основе их обычной активности. • Выявление отклонений от нормального поведения с помощью алгоритмов машинного обучения.
3.	Регулярный аудит и проверка политик безопасности : • Проверка прав доступа и действий пользователей. • Анализ журналов аудита на наличие подозрительных записей.
4.	Использование инструментов предотвращения утечек данных (DLP) : • Контроль передачи конфиденциальной информации за пределы организации.

Заключение

Аномалии в трафике и действиях пользователей могут быть ранними сигналами о потенциальных угрозах. Важно своевременно выявлять такие отклонения и принимать меры для их устранения. Для этого необходимо сочетать автоматизированные инструменты анализа с регулярными проверками и обучением сотрудников.

VII. Гибридные методы :

Комбинирование сигнатурного и аномального подходов

Комбинирование сигнатурного и аномального подходов к обнаружению угроз

— это гибридный метод, который объединяет преимущества обоих подходов для повышения эффективности систем защиты информации. Рассмотрим каждый из подходов отдельно, а затем обсудим, как их комбинирование может быть реализовано.

1. Сигнатурный подход

Сигнатурный подход основывается на использовании заранее определенных "сигнатур" (уникальных характеристик) известных угроз. Эти сигнатуры представляют собой фрагменты кода, хэши файлов, паттерны сетевого трафика или другие идентифицируемые признаки вредоносных программ или атак.

Преимущества:

- Высокая точность обнаружения известных угроз.
- Низкий уровень ложноположительных срабатываний (False Positives).
- Простота реализации и интерпретации результатов.

Недостатки:

- Неэффективен против новых или неизвестных угроз (Zero-Day атаки).
- Требуется постоянное обновления баз сигнатур.
- Зависимость от наличия актуальной информации о новых угрозах.

2. Аномальный подход

Аномальный подход фокусируется на выявлении отклонений от нормального поведения системы. Вместо поиска конкретных сигнатур, этот метод анализирует данные и модели поведения, чтобы определить, что является "нормальным", а что — "подозрительным".

Преимущества:

- Способен обнаруживать новые и неизвестные угрозы (например, Zero-Day атаки).
- Не требует предварительного знания о сигнатурах угроз.
- Универсальность: применим к различным типам систем.

Недостатки:

- Высокий уровень ложноположительных срабатываний (False Positives), так как любое отклонение от нормы может быть ошибочно классифицировано как угроза.
- Сложность в определении "нормального" поведения системы, особенно в динамичных средах.
- Требуется значительных вычислительных ресурсов для анализа больших объемов

3. Комбинирование подходов

Комбинирование сигнатурного и аномального подходов позволяет объединить их сильные стороны, минимизируя недостатки каждого из них. Такой гибридный метод может быть реализован следующим образом: 3.1.

3.1. Параллельная работа двух модулей

- В системе одновременно работают два модуля: сигнатурный и аномальный.
- Сигнатурный модуль проверяет данные на наличие известных угроз.
- Аномальный модуль анализирует поведение системы и выявляет отклонения от нормы.
- Если один из модулей обнаруживает подозрительную активность, система генерирует сигнал тревоги.

3.2. Использование сигнатур для обучения аномального детектора

- Сигнатурный подход используется для создания базы данных известных угроз.
- На основе этой базы аномальный детектор обучается распознавать закономерности, характерные для вредоносной активности.
- Это помогает уменьшить количество ложноположительных срабатываний и повысить точность обнаружения.

3.3. Двухэтапный анализ

- На первом этапе применяется сигнатурный подход для быстрого обнаружения известных угроз.
- Если сигнатурный подход не выявил угрозу, данные передаются на второй этап, где используется аномальный анализ для выявления потенциально новых угроз.

3.4. Гибридные алгоритмы машинного обучения

- Современные системы часто используют алгоритмы машинного обучения, которые объединяют сигнатурные и поведенческие данные.
- Например, можно использовать нейронные сети, которые принимают на вход как сигнатурные данные (хэши файлов, паттерны трафика), так и поведенческие данные (логи событий, метрики производительности).
- Такие модели могут адаптироваться к новым угрозам и улучшать свою точность со временем.

3.5. Контекстное обогащение данных

- Сигнатурный подход предоставляет информацию о конкретных угрозах.
- Аномальный подход добавляет контекст, например, частоту событий, временные рамки или взаимосвязь между действиями.
- Комбинированный анализ позволяет более точно классифицировать события как угрозы или безопасные действия.

Пример реализации

Предположим, что система мониторинга обнаруживает подозрительный файл:

1. Сигнатурный анализ**: Файл проверяется по базе данных известных сигнатур. Если сигнатура найдена, файл классифицируется как вредоносный.
2. Аномальный анализ**: Если сигнатура не найдена, система анализирует поведение файла. Например, если файл пытается получить доступ к критическим системным файлам или отправить данные в сеть, это может быть признаком угрозы.
3. Гибридное решение**: Если аномальный анализ выявляет подозрительное поведение, но не уверен в его злонамеренности, система может запросить дополнительные данные (например, через облачный сервис) или поместить файл в карантин для дальнейшего анализа.

Преимущества комбинированного подхода

1. Высокая точность: Объединение двух методов снижает вероятность пропуска угроз и минимизирует ложноположительные срабатывания.
 2. Защита от Zero-Day атак: Аномальный подход компенсирует слабость сигнатурного метода в отношении новых угроз.
 3. Адаптивность: Гибридные системы могут обучаться и адаптироваться к изменяющимся угрозам.
 4. **Масштабируемость: Подходит для различных типов систем и сред###
- Заключение

Комбинирование сигнатурного и аномального подходов является мощным инструментом в области кибербезопасности. Оно позволяет создавать системы, которые эффективно обнаруживают как известные, так и новые угрозы, обеспечивая высокий уровень защиты информационных систем. Реализация такого подхода требует тщательного проектирования и использования современных технологий, таких как машинное обучение и анализ больших данных.